

Relatorio de Auditoria Tecnica

Seguranca, logica de negocio, resiliencia e configuracao

Projeto Vibe - shorts-de-vibe

Data da analise: 30/09/2026

Escopo: frontend Vanilla JavaScript, API Laravel/PHP, MySQL, autenticacao Sanctum, Cloudinary, CORS, CSP, filas/cache, Docker Compose, migrations, dependencias e historico Git local.

Conclusao executiva: nao foram encontrados erros de sintaxe nos 85 arquivos PHP analisados nem nos 11 arquivos JavaScript. Os testes PHPUnit foram executados com codigo de saida 0. Foram identificados pontos de seguranca, privacidade, resiliencia e prontidao para producao que devem ser tratados antes de um ambiente publico.

1. Metodologia e evidencias

- Inspecao estatica de rotas, controllers, models, resources, middleware, migrations, configuracoes, frontend e infraestrutura.
- Busca por segredos, SQL dinamico, XSS, URLs de midia, autorizacao, rate limiting, tokens, CORS, CSP e uploads.
- PHP 8.5.0: 85 arquivos PHP, nenhum erro de sintaxe.
- Node.js: 11 arquivos JavaScript, nenhum erro de sintaxe.
- PHPUnit: 22 testes executados com codigo de saida 0; o cache de resultados nao pode ser escrito por permissao.
- Composer validate: composer.json valido. Composer audit nao consultou Packagist porque a rede recusou a conexao.

2. Achados criticos

CRITICO - Seguranca

Segredos permanecem em historico Git local de backup

Localizacao: Commit 3301de9, backend/.env; branch backup-before-github-publish

Analise tecnica e impacto: O commit antigo contem APP_KEY, DB_PASSWORD, MAIL_PASSWORD e CLOUDINARY_API_SECRET. A branch main publicada foi recriada sem esses arquivos, mas a branch de backup ainda aponta para esse historico.

Impacto: Push acidental da branch de backup ou compartilhamento do repositorio local pode expor credenciais e permitir acesso ao banco, e-mail e Cloudinary.

Correcao sugerida: Excluir ou proteger a branch de backup, remover objetos sensiveis do historico com ferramenta apropriada e rotacionar todas as credenciais que ja existiram.

```
git branch -D backup-before-github-publish
# rotacionar APP_KEY, banco, SMTP e Cloudinary
```

3. Achados altos

ALTO - Seguranca e privacidade

Perfil privado aceita seguidores sem aprovacao

Localizacao: backend/app/Http/Controllers/Api/FollowController.php, store

Analise tecnica e impacto: O endpoint permite seguir qualquer usuario com allow_following=true e nao verifica is_private nem cria estado de solicitacao. A camada de visibilidade bloqueia videos privados, mas o estado de seguidores fica inconsistente.

Impacto: Usuarios podem acumular seguidores que nao deveriam ser aceitos e a interface pode apresentar resultado diferente da politica de privacidade.

Correcao sugerida: Para perfil privado, criar follow_requests e responder pending; somente aprovacao deve inserir em follows.

```
if ($user->is_private) {
    return response()->json(['data' => ['status' => 'pending']], 202);
}
```

CORS de producao nao inclui a origem real do frontend

Localizacao: backend/config/cors.php, allowed_origins

Analise tecnica e impacto: A lista padrao contem apenas localhost e portas de desenvolvimento. Sem CORS_ALLOWED_ORIGINS correto, o navegador bloqueia chamadas do frontend online; allowed_methods tambem esta como *.

Impacto: Falha de login, feed e upload em ambiente online; uma origem excessiva aumenta a superficie de ataque.

Correcao sugerida: Definir origens reais no ambiente de producao e limitar metodos aos usados.

```
CORS_ALLOWED_ORIGINS=https://app.exemplo.com
allowed_methods: ['GET', 'POST', 'PUT', 'PATCH', 'DELETE', 'OPTIONS']
```

Bearer token fica no armazenamento do navegador

Localizacao: api-client.js e auth-form.js, persistencia de authToken

Analise tecnica e impacto: A aplicacao usa Bearer token em localStorage. Qualquer XSS futuro no mesmo origin pode ler o token ate expiracao ou logout.

Impacto: Roubo de sessao e acesso a operacoes da conta.

Correcao sugerida: Preferir cookie HttpOnly, Secure e SameSite com Sanctum stateful. Se Bearer for mantido, reduzir validade e revogar tokens antigos no login.

```
Cookie HttpOnly + Secure + SameSite=Lax
# e protecao CSRF para a sessao
```

4. Achados medios

Abrir Menções marca todas as notificacoes como lidas

Localizacao: script.js, abrirNotificacoes, aproximadamente 2328-2358

Analise tecnica e impacto: A lista e filtrada para mentions no frontend, mas a chamada posterior a /notifications/read-all atualiza todas as notificacoes do usuario.

Impacto: Curtidas, respostas e follows perdem o estado nao lido sem terem sido vistas.

Correcao sugerida: Marcar apenas os IDs exibidos ou criar endpoint para marcar por tipo.

```
await Promise.all(visible.map(item => apiRequest('/notifications/{id}/read', {method:'POST'})));
```

Chave de idempotencia pode ficar presa apos execucao

Localizacao: backend/app/Http/Middleware/Idempotency.php, handle

Analise tecnica e impacto: O registro e criado antes da rota. Se o handler lancar execucao, a chave nao e apagada e a mesma acao retorna 409 ate a limpeza por tempo.

Impacto: Falha transitoria pode impedir repeticao por ate dez minutos e prender a fila offline.

Correcao sugerida: Usar try/catch para remover a chave quando houver execucao e persistir apenas respostas bem sucedidas.

```
try { $response = $next($request); } catch (Throwable $e) { $record->delete(); throw $e; }
```

Estatísticas do perfil carregam e contam todos os videos

Localizacao: backend/app/Http/Controllers/Api/ProfileController.php, userData

Analise tecnica e impacto: Cada abertura de perfil carrega todos os videos e executa contagens de likes, comentarios e favoritos.

Impacto: Latencia e memoria crescem linearmente; perfis grandes podem ficar lentos.

Correcao sugerida: Mover agregacoes para SUM/COUNT SQL ou tabela de metricas e paginar videos.

```
selectRaw('SUM(view_count) views, SUM(shares_count) shares')
```

Relevancia cria uma ordenacao SQL por interesse

Localizacao: backend/app/Http/Controllers/Api/VideoController.php, index

Analise tecnica e impacto: Cada interesse adiciona CASE WHEN ... LIKE na ordenacao e pode impedir uso eficiente de indices.

Impacto: Feed de descoberta degrada conforme interesses e volume de videos aumentam.

Correcao sugerida: Usar FULLTEXT/MATCH ou pontuacao calculada em job, limitando termos.

5. Achados baixos

CSP permite conexoes para qualquer origem HTTPS

Localizacao: index.html, Content-Security-Policy, connect-src

Analise tecnica e impacto: connect-src contem https: sem lista de hosts. Scripts locais continuam limitados, mas um codigo comprometido pode comunicar com qualquer endpoint HTTPS.

Impacto: Aumenta alcance de exfiltracao e comunicacao de um codigo comprometido.

Correcao sugerida: Trocar por hosts exatos da API, Cloudinary e desenvolvimento.

```
connect-src 'self' https://api.exemplo.com https://res.cloudinary.com http://localhost:8000
```

Acao de moderacao nao trata rejeicao no frontend

Localizacao: script.js, carregarModeracao, listener de resolver

Analise tecnica e impacto: O callback async chama apiRequest sem try/catch. Em falha, surge unhandled rejection e o botao pode permanecer desabilitado.

Impacto: Moderador recebe feedback incompleto e precisa recarregar a tela.

Correcao sugerida: Adicionar try/catch/finally e restaurar disabled.

```
try { await apiRequest(...); } catch (e) { setFeedStatus(e.message); } finally { resolve.disabled = false; }
```

CDN de ícones sem Subresource Integrity

Localizacao: index.html, link cdnjs.cloudflare.com

Análise técnica e impacto: O CSS externo não possui integrity/crossorigin.

Impacto: Alteração indevida do recurso externo pode mudar a interface; risco reduzido por ser CSS.

Correção sugerida: Fixar versão, adicionar SRI ou empacotar o CSS localmente.

6. Informativos e pendências

- backend/.env.example usa MAIL_MAILER=log; confirmação e recuperação não serão enviadas sem SMTP.
- Composer audit precisa ser executado com acesso ao Packagist.
- PHPUnit passou, mas o cache não pode ser escrito por permissão.
- Fila e cache usam database; em produção, executar worker e aplicar migrations.
- A main publicada não contém .env, vendor, node_modules, tmp ou SQL; a branch local de backup deve ficar fora de qualquer push.

7. Validações executadas

Verificação	Resultado
PHP syntax	85 arquivos, 0 erros
JavaScript syntax	11 arquivos, 0 erros
PHPUnit	22 testes, código de saída 0
Composer validate	composer.json válido
Composer audit	Não concluído: rede indisponível
Git main	Publicado em github.com/JimmyHendrik/shorts-de-vibe

Prioridade: remover e rotacionar segredos do histórico local; definir CORS e SMTP de produção; corrigir follow de perfil privado, idempotência e notificações; depois otimizar estatísticas e endurecer CSP/CDN.